

Informe de Conclusión y Diagnóstico Post-Intervención: OmniSalud

Resumen de Gestión de Riesgos, Métricas y Plan de Certificación APDP

Unidad de Negocio: OmniSalud (Servicios Clínicos y Telemedicina)
Consultor Líder: Gonzalo Vega Batyi, Abogado / DPO
Marco de Referencia: ISO 31000:2018 | ISO 27701 (SGPI)
Fecha de Cierre: Abril 2026
Próxima Revisión: Octubre 2026 (Control Semestral de Métricas)

1. Diagnóstico de Cierre y Resumen Ejecutivo

Tras completar el ciclo de auditoría bajo la metodología **ISO 31000**, se ha transformado el escenario de **Riesgo Extremo** detectado en el diagnóstico inicial (contaminación de datos de 404 ciudadanos) en un **Escenario de Riesgo Controlado**. La unidad ahora cuenta con bases legales sólidas y una estructura organizativa que permite la trazabilidad de cada dato sensible, mitigando la exposición ante la Ley 21.719.

1.1 Matriz Visual de Mitigación del Riesgo

A continuación, se representa la reducción de los niveles de exposición tras la implementación de los controles normativos y organizativos. *(Escala de Evaluación: 1: Bajo/Controlado - 5: Extremo/Crítico)*

Dimensión Evaluada	Riesgo Inicial (Pre-Auditoría)	Riesgo Residual (Post-Controles)	Impacto de Mejora
Licitud (Ley 21.719)	(5)	(1)	Riesgo Mitigado
Confidencialidad	(5)	(2)	Riesgo Aceptable
Integridad	(4)	(1)	Riesgo Mitigado
Accountability	(5)	(1)	Riesgo Mitigado
Seguridad (Ley 21.663)	(4)	(2)	Riesgo Aceptable

2. Matriz de Medidas Implementadas

Categoría	Medida de Control	Objetivo Normativo
Gobernanza	Manual de Procedimientos para el Administrador	Establecer responsabilidad proactiva (Accountability).
Privacidad	Aislamiento Lógico y Tokenización	Garantizar el Principio de Finalidad y Limitación (Art. 9).

Categoría	Medida de Control	Objetivo Normativo
Seguridad	Cifrado AES-256 en Reposo (Datos Sensibles)	Proteger la infraestructura crítica de salud (Ley 21.663).
Contractual	Anexo de Secreto Profesional (Cuerpo Operativo)	Blindaje legal ante fugas de información interna.

3. Proyección de Mejora y Métricas de Cumplimiento (6 meses)

La gestión de riesgos es un proceso dinámico. Se establece un periodo de observación de **180 días** para analizar la eficacia de los controles mediante los siguientes indicadores clave de desempeño (KPIs):

3.1 Indicadores Clave de Desempeño

- **Nivel de Adopción (NA):** % de cumplimiento de las tareas del Manual de Procedimientos por parte del Administrador. (Meta: >95%).
- **Integridad del Dato (ID):** Número de incidencias por "Contaminación Cruzada" detectadas en auditorías aleatorias. (Meta: 0).
- **Cumplimiento Operativo (CO):** % de empleados capacitados y certificados en el nuevo protocolo de reserva legal. (Meta: 100%).

3.2 Revisión y Ajuste (Octubre 2026)

Se realizará una revisión técnica para analizar las métricas acumuladas y realizar ajustes en los manuales de procedimiento, asegurando que el modelo de prevención siga siendo realista y efectivo frente a la evolución tecnológica del holding.

4. Estrategia de Certificación ante la APDP

Como mecanismo de blindaje jurídico superior, se iniciará el proceso de **Certificación del Modelo de Prevención de Infracciones** ante la Agencia de Protección de Datos Personales (APDP).

Beneficios Estratégicos:

1. **Atenuante Calificado:** La certificación permite rebajar sustancialmente las multas potenciales (de hasta 20.000 UTM) al acreditar la implementación de un sistema de gestión de riesgos serio y auditable.
2. **Reputación Corporativa:** Posiciona a OmniSalud como líder en cumplimiento normativo y ética de datos en el sector salud.
3. **Seguridad Jurídica:** Valida externamente que los controles implementados cumplen con el estándar de "Debida Diligencia" exigido por la normativa chilena.

Resiliencia Técnica y Protección de Infraestructura Crítica de Salud

Este apartado consolida el diagnóstico de seguridad lógica y las garantías de integridad implementadas para blindar la unidad frente a incidentes que puedan comprometer la disponibilidad de los servicios de salud y la confidencialidad de la información.

1. Diagnóstico de Ciberseguridad Transversal

Se ha determinado que la vulnerabilidad principal de **OmniSalud** no residía únicamente en la falta de bases legales, sino en la **exposición de la superficie de ataque** al compartir infraestructura no segmentada con filiales comerciales. Esta falta de segregación facilitaba el movimiento lateral de posibles amenazas (por ejemplo, *Ransomware*) desde la red corporativa hacia la base de datos clínica.

1.1 Estado de la Seguridad Lógica Post-Auditoría

- **Cifrado en Reposo:** Implementación obligatoria del estándar AES-256 para la totalidad de la base `omnisalud_clientes.csv`.
- **Perímetro Lógico:** Establecimiento de *VLANs* segregadas y reglas de *Firewall* de aplicación que bloquean peticiones no autorizadas provenientes del servidor central del Holding.

2. Medidas de Ciberseguridad Implementadas (Controles Técnicos)

Control Técnico Implementado	Requisito Ley 21.663	Impacto Directo en la Resiliencia
MFA (Autenticación Multifactor)	Control de Acceso Robusto	Mitigación del 99% de riesgos por suplantación de identidad del personal clínico.
Tokenización de IDs	Protección de Activos de Información	Evita la re-identificación de pacientes en caso de exfiltración de datos.
Protocolo de Reporte Rápido	Deber de Notificación de Incidentes	Notificación obligatoria a la Agencia Nacional de Ciberseguridad en un plazo máximo de 4 horas.
Backup Inmutable	Garantía de Continuidad Operativa	Asegura la recuperación íntegra de fichas clínicas ante ataques de secuestro de datos.

3. Proyección de Madurez y Ciber-Resiliencia

La ciberseguridad en OmniSalud se proyecta como un sistema vivo de mejora continua. Se ha establecido un marco para la creación de un **Plan de Respuesta ante Incidentes (CSIRT Interno)**, el cual será evaluado mediante simulacros técnicos en el próximo hito de revisión semestral.

3.1 Métricas de Ciber-Cumplimiento

- **MTTR (Mean Time to Respond):** Tiempo medio de respuesta ante alertas de seguridad. (Meta: < 30 minutos).
- **Gestión de Vulnerabilidades:** Número de hallazgos de severidad alta en escaneos mensuales. (Meta: 0).
- **Cumplimiento de Parches:** Porcentaje de sistemas críticos actualizados en menos de 72 horas desde la liberación del parche. (Meta: 100%).

5. Conclusión Final y Dictamen de Auditoría

La intervención en **OmniSalud** concluye con un dictamen de **CUMPLIMIENTO VERIFICADO**, tras haber completado con éxito la transición de una arquitectura abierta y vulnerable hacia un modelo basado en principios de **Confianza Cero (Zero Trust)**. Este blindaje técnico y legal establece una estructura de control escalable y alineada con los más altos estándares internacionales de privacidad, lo que permite al Directorio asegurar proactivamente la continuidad de los servicios de salud y la reserva absoluta de los diagnósticos de los pacientes. Con esta implementación, la unidad no solo cumple con las exigencias de las Leyes 21.719 y 21.663, sino que queda blindada reputacionalmente para un crecimiento corporativo seguro y resiliente.
